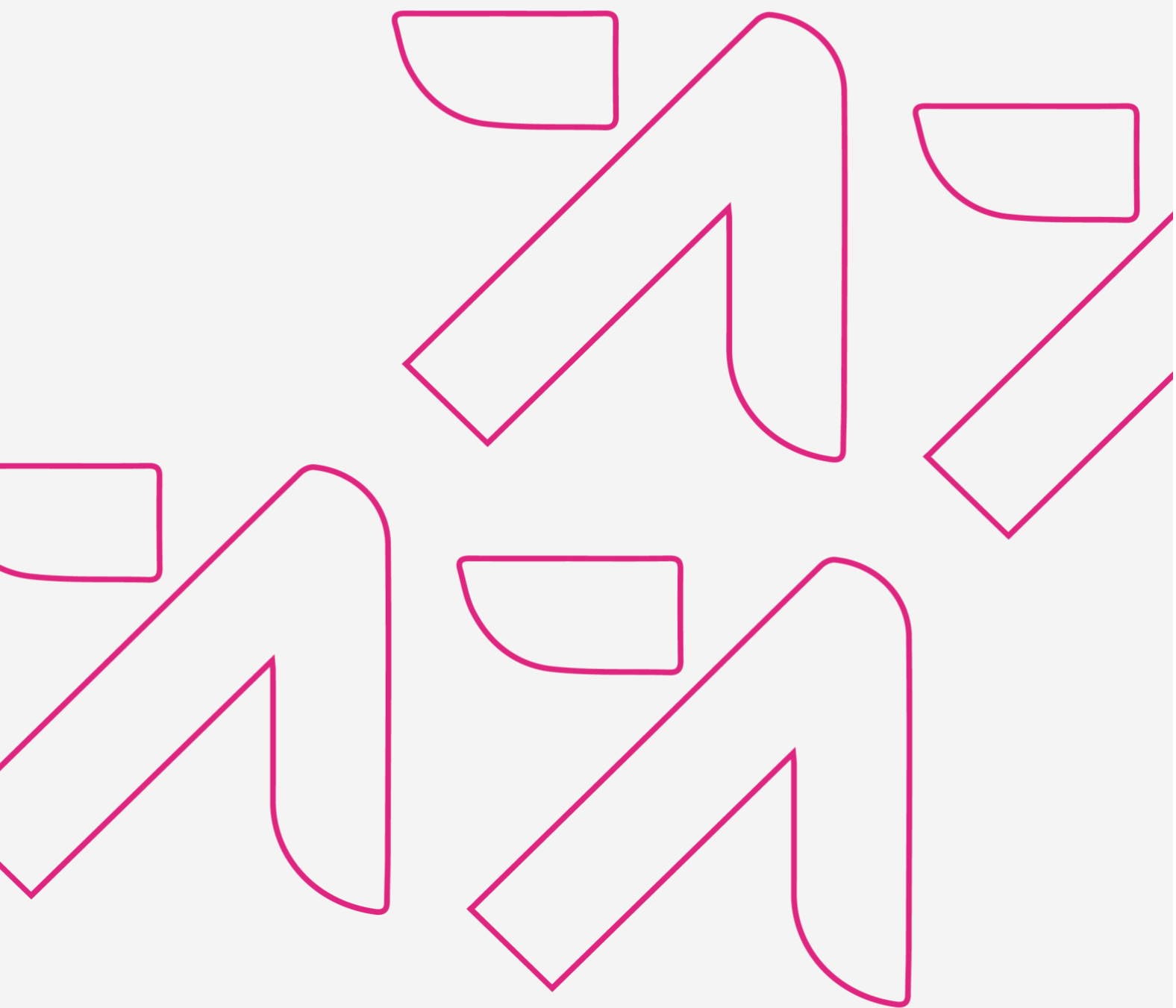




Máster de

Ciberseguridad Hacking Ético

[Módulo Incidentes de Ciberseguridad]

Curso académico 2026/2027 - Edición Presencial

Tema 1. Introducción a la ciberseguridad y la prevención de incidentes

Encaje en el curso 2026/2027: tema 1 del temario oficial, dentro del RA1 (planes de prevención y concienciación). Es la base de vocabulario de todo el módulo.

1. Qué es la ciberseguridad

La ciberseguridad es el conjunto de medidas técnicas, organizativas y humanas que protegen los sistemas, las redes y la información frente a accesos, usos o daños no autorizados.

No es un producto que se compra ni un estado que se alcanza: es un proceso continuo de prevenir, detectar, responder y aprender. Este módulo se centra en la segunda mitad de esa frase, pero empieza por la primera, porque el incidente más barato es el que no llega a ocurrir.

2. Evento, alerta, incidente y brecha

Cuatro palabras que se confunden y que conviene separar desde el primer día:

Término	Qué es	Ejemplo
Evento	Cualquier cosa observable que ocurre en un sistema	Un usuario inicia sesión
Alerta	Un evento, o un conjunto de ellos, que una herramienta marca como sospechoso	Diez inicios de sesión fallidos en un minuto
Incidente	Un hecho confirmado que compromete o amenaza la seguridad	Un atacante ha entrado con una contraseña adivinada
Brecha de datos personales	Un incidente que afecta a datos personales	El atacante ha descargado la base de clientes

No toda alerta es un incidente (hay falsos positivos) y no todo incidente es una brecha. La diferencia importa: una brecha de datos personales activa obligaciones legales que veremos en el tema 10.

3. La tríada CID

Toda la seguridad de la información se resume en proteger tres propiedades.

3.1. Confidencialidad

Solo accede a la información quien está autorizado. Se protege con control de acceso, cifrado y clasificación de la información. Se rompe con una fuga de datos, un correo enviado al destinatario equivocado o una contraseña robada.

3.2. Integridad

La información es exacta y no ha sido modificada sin autorización. Se protege con hashes, firmas digitales, control de versiones y permisos de escritura limitados. Se rompe cuando alguien altera un registro, una factura o un fichero de configuración.

3.3. Disponibilidad

La información y los servicios están accesibles cuando se necesitan. Se protege con redundancia, copias de seguridad y planes de continuidad. Se rompe con un ataque de denegación de servicio, un ransomware o una avería sin respaldo.

3.4. Las otras dos dimensiones

El Esquema Nacional de Seguridad añade dos dimensiones que en gestión de incidentes son imprescindibles:

- **Autenticidad:** poder asegurar que alguien es quien dice ser y que un dato procede de donde dice proceder.
- **Trazabilidad:** poder saber quién hizo qué y cuándo. Sin trazabilidad no hay investigación posible.

3.5. La tríada en una empresa

Cada incidente afecta a una o varias dimensiones, y saber a cuál ayuda a decidir la respuesta:

Incidente	Dimensión afectada
Ransomware que cifra el servidor de ficheros	Disponibilidad (y confidencialidad si además roban los datos)
Empleado que consulta nóminas ajenas	Confidencialidad
Cambio del número de cuenta en una factura	Integridad
Caída de la web por un ataque DDoS	Disponibilidad

4. Tipos de ataques

4.1. Ataques pasivos

El atacante observa sin modificar nada, por lo que son muy difíciles de detectar.

- **Escucha de tráfico (sniffing):** capturar comunicaciones sin cifrar.
- **Análisis de tráfico:** aunque el contenido vaya cifrado, deducir información de quién habla con quién, cuándo y cuánto.
- **Reconocimiento con fuentes abiertas (OSINT):** recopilar información pública de la organización.

La defensa es sobre todo preventiva: cifrar las comunicaciones, segmentar la red y reducir la información que se publica.

4.2. Ataques activos

El atacante modifica datos o altera el funcionamiento del sistema. Hacen más ruido y, por tanto, se pueden detectar.

- **Suplantación de identidad:** hacerse pasar por otra persona o sistema.
- **Modificación de mensajes:** alterar una comunicación en tránsito (ataque de intermediario).
- **Repetición:** capturar un mensaje válido y reenviarlo más tarde.
- **Denegación de servicio:** saturar un servicio hasta dejarlo inaccesible.
- **Ejecución de código malicioso:** malware en cualquiera de sus formas.

4.3. Vectores de entrada más habituales

Los informes anuales del sector coinciden año tras año en los mismos caminos de entrada:

- Credenciales robadas, reutilizadas o débiles.
- Phishing y otras formas de ingeniería social.
- Vulnerabilidades sin parchear en servicios expuestos a Internet.
- Errores de configuración, sobre todo en la nube.
- Proveedores y cadena de suministro.

5. Estrategias de defensa

5.1. Defensa en profundidad

Ningún control es infalible, así que se colocan varias capas: si una falla, la siguiente frena o al menos avisa. Las capas habituales son políticas y personas, perímetro, red interna, equipo, aplicación y dato.

5.2. Tipos de controles

Tipo	Para qué sirve	Ejemplos
Preventivo	Evitar que ocurra	MFA, cortafuegos, parches, formación
Detectivo	Enterarse de que ocurre	IDS, SIEM, revisión de registros
Correctivo	Reparar el daño	Copias de seguridad, reinstalación
Disuasorio	Quitar las ganas	Avisos legales, cámaras visibles

5.3. Principios que se repiten

- **Mínimo privilegio:** cada usuario y cada servicio, solo con lo que necesita.

- Denegación por defecto: lo que no está permitido de forma explícita, está prohibido.
- Reducir la superficie de ataque: lo que no se usa, se desactiva.
- Asumir la brecha: diseñar pensando que alguien acabará entrando.

6. Protección de una red corporativa

Un esquema mínimo razonable para una pyme:

- Cortafuegos perimetral con reglas restrictivas y red segmentada (usuarios, servidores, invitados).
- Acceso remoto solo por VPN o acceso de confianza cero, con MFA.
- Equipos actualizados, con antimalware o EDR y disco cifrado.
- Correo con filtrado antiphishing y SPF, DKIM y DMARC configurados.
- Copias de seguridad siguiendo la regla 3-2-1, con una copia desconectada.
- Registros centralizados y alguien que los mire.
- Personas formadas y un canal sencillo para avisar de algo raro.

7. El ciclo de gestión de incidentes

Todo el módulo sigue este recorrido, que es el del modelo clásico de NIST:

1. **Preparación:** planes, herramientas, formación y concienciación (temas 1 y 2).
2. **Detección y análisis:** clasificar, detectar y auditar (temas 3, 4 y 5).
3. **Contención, erradicación y recuperación:** evidencias, investigación y medidas (temas 6, 7 y 8).
4. **Actividad posterior:** lecciones aprendidas, notificación y comunicación (temas 9 y 10).

No es una línea recta: durante un incidente real se vuelve atrás muchas veces, y lo aprendido al final alimenta la preparación del siguiente.

8. Quién es quién

- **SOC (centro de operaciones de seguridad):** el equipo que vigila y detecta, normalmente 24 horas.
- **CSIRT o CERT:** equipo de respuesta a incidentes. Puede ser interno o de referencia nacional.
- **INCIBE-CERT:** CSIRT de referencia para ciudadanía y empresas privadas en España.
- **CCN-CERT:** CSIRT de referencia para el sector público y para los sistemas dentro del ENS.

- **AEPD:** autoridad de control en protección de datos; recibe las notificaciones de brechas de datos personales.
- **DPD (delegado de protección de datos):** la persona de la organización que coordina todo lo relativo a datos personales.

Para ampliar

- NIST SP 800-61: guía de gestión de incidentes de seguridad informática.
- Guía Nacional de Notificación y Gestión de Ciberincidentes (INCIBE-CERT / CCN-CERT).
- Real Decreto 311/2022 (Esquema Nacional de Seguridad): dimensiones de seguridad.
- INCIBE: glosario de términos de ciberseguridad.